

Отчёт по индивидуальному проекту № 5

Основы информационной безопасности

Луангсуваннавонг Сайпхачан, НКАбд-01-24

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	8
5	Выводы	19

Список иллюстраций

4.1	Запуск локального сервера	8
4.2	Сетевые настройки браузера	8
4.3	Смена прокси-сервера	9
4.4	Запуск программы Burp Suite	9
4.5	Проверка прокси-сервера	9
4.6	Изменение параметра браузера	10
4.7	Перехват сайта	10
4.8	Страница входа на сайт	11
4.9	Вход на сайт	11
4.10	Вкладка в Burp Suite	12
4.11	Отправка информации на вкладку «Intruder»	13
4.12	Выбор параметра для полезной нагрузки	14
4.13	Создание полезной нагрузки для первого параметра	14
4.14	Создание полезной нагрузки для второго параметра	15
4.15	Начинаем атаку	15
4.16	Результат проверки	16
4.17	Результат проверки	16
4.18	Отправка результата на вкладку «Repeater»	17
4.19	Отправка запроса на перенаправление	17
4.20	Визуализация сайта	18

Список таблиц

1 Цель работы

Научиться использовать Burp Suite.

2 Задание

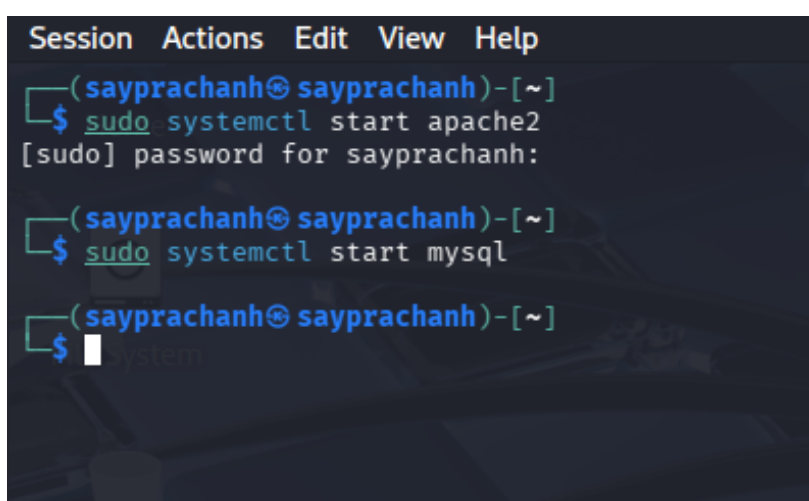
Использование Burp Suite

3 Теоретическое введение

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения.

4 Выполнение лабораторной работы

Во-первых, я запускаю локальный сервер DVWA для тестирования Burp Suite.(рис. 4.1)



```
Session Actions Edit View Help
(sayprachanh@sayprachanh)-[~]
$ sudo systemctl start apache2
[sudo] password for sayprachanh:
(sayprachanh@sayprachanh)-[~]
$ sudo systemctl start mysql
(sayprachanh@sayprachanh)-[~]
$
```

Рисунок 4.1: Запуск локального сервера

Затем я перехожу в настройки сети браузера и настраиваю прокси так, чтобы браузер использовал тот же HTTP-прокси, что и Burp Suite(рис. Рисунок 4.2).

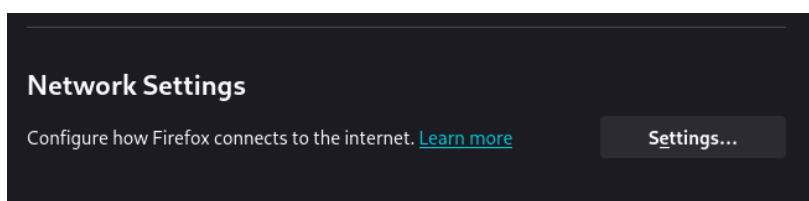


Рисунок 4.2: Сетевые настройки браузера

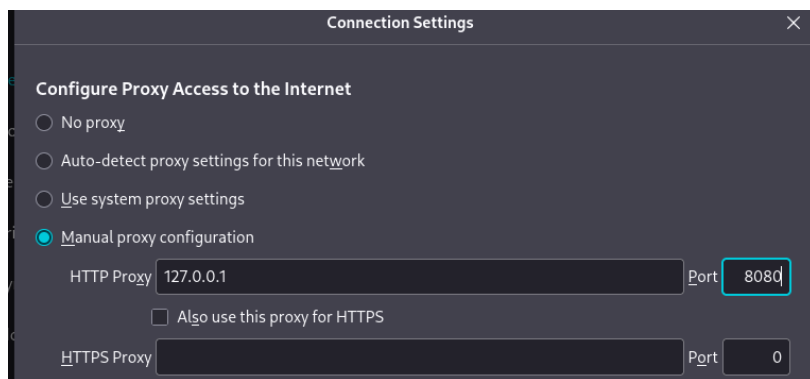


Рисунок 4.3: Смена прокси-сервера

Поскольку программа Burp Suite уже предустановлена в Kali Linux, я запускаю Burp Suite сразу. Затем я перехожу на вкладку Прокси в Burp Suite и проверяю настройки прокси, убеждаясь, что мы используем тот же прокси(рис. Рисунок 4.4).

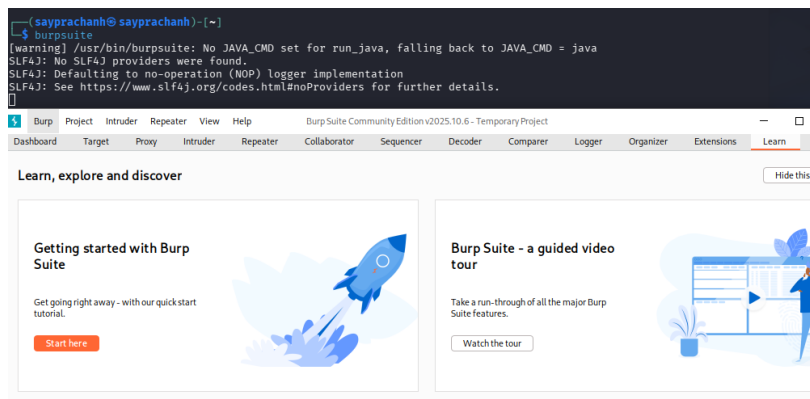


Рисунок 4.4: Запуск программы Burp Suite

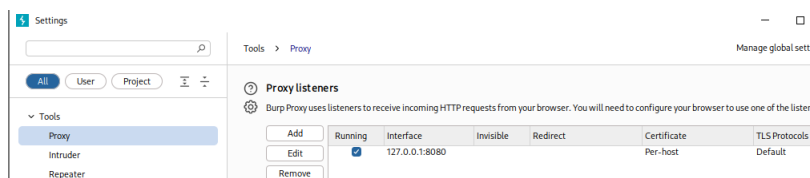


Рисунок 4.5: Проверка прокси-сервера

В конфигурации браузера я устанавливаю параметр `network.allow_hijacking_localhost` в значение `true`, чтобы Burp Suite правильно работал с локальным сервером(рис. 4.6).

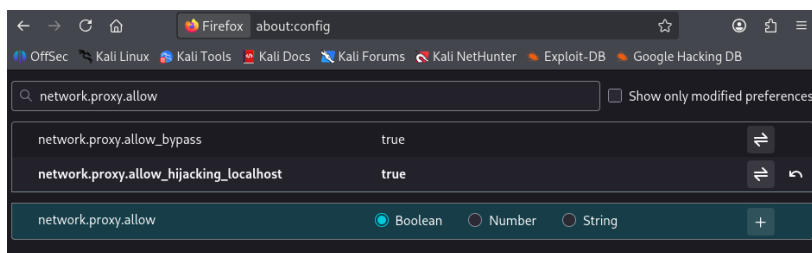


Рисунок 4.6: Изменение параметра браузера

Далее в Burp Suite я включаю кнопку Intercept, переключая её с off на on, и возвращаюсь к DVWA в браузере. В результате вкладка в Burp Suite меняется(рис. Рисунок 4.7).

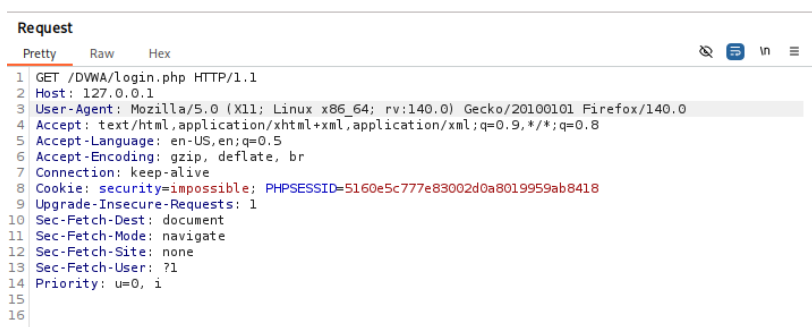
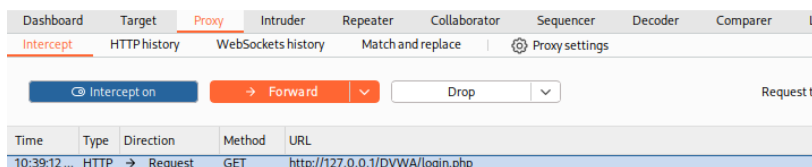


Рисунок 4.7: Перехват сайта

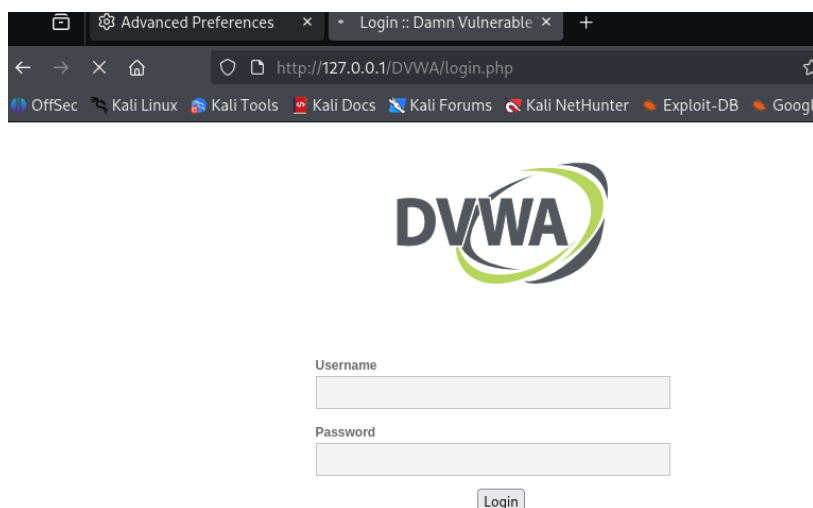


Рисунок 4.8: Страница входа на сайт

Затем я пытаюсь ввести неправильные учётные данные для входа в DVWA и возвращаюсь в Burp Suite. Теперь он отображает вкладку, содержащую информацию о моей попытке входа с неверным логином и паролем(рис. Рисунок 4.9).

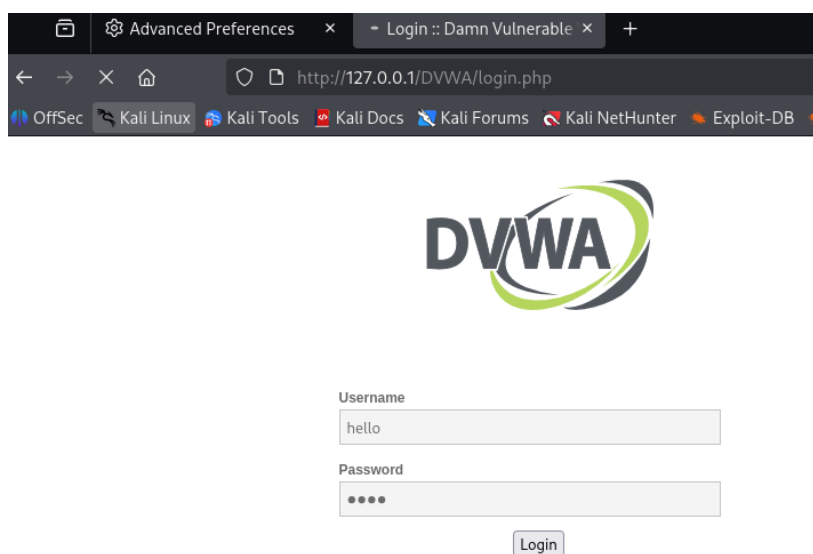


Рисунок 4.9: Вход на сайт

Time	Type	Direction	Method	URL
10:39:12 ...	HTTP	→ Request	GET	http://127.0.0.1/DVWA/login.php
10:40:39...	HTTP	→ Request	POST	http://127.0.0.1/DVWA/login.php



Рисунок 4.10: Вкладка в Burp Suite

Я отправляю информацию о моей попытке входа на вкладку Intruder. На этой вкладке я выделяю имя пользователя и пароль и выбираю позицию Add для добавления полезной нагрузки (payload) атаки, затем меняю тип атаки на Cluster bomb attack для выбора типа атаки на сайт(рис. Рисунок 4.11).

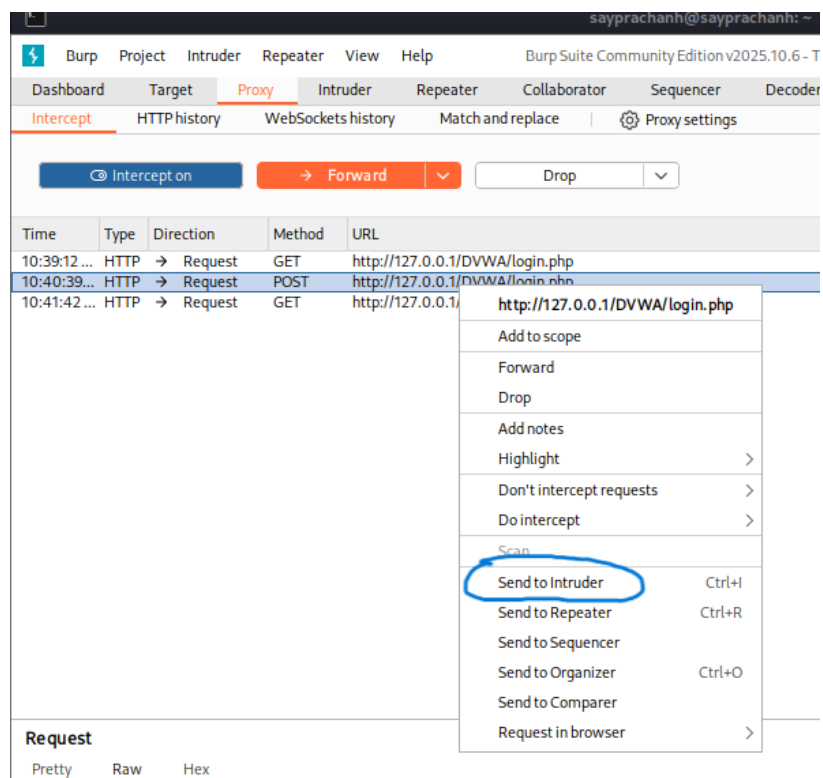


Рисунок 4.11: Отправка информации на вкладку «Intruder»

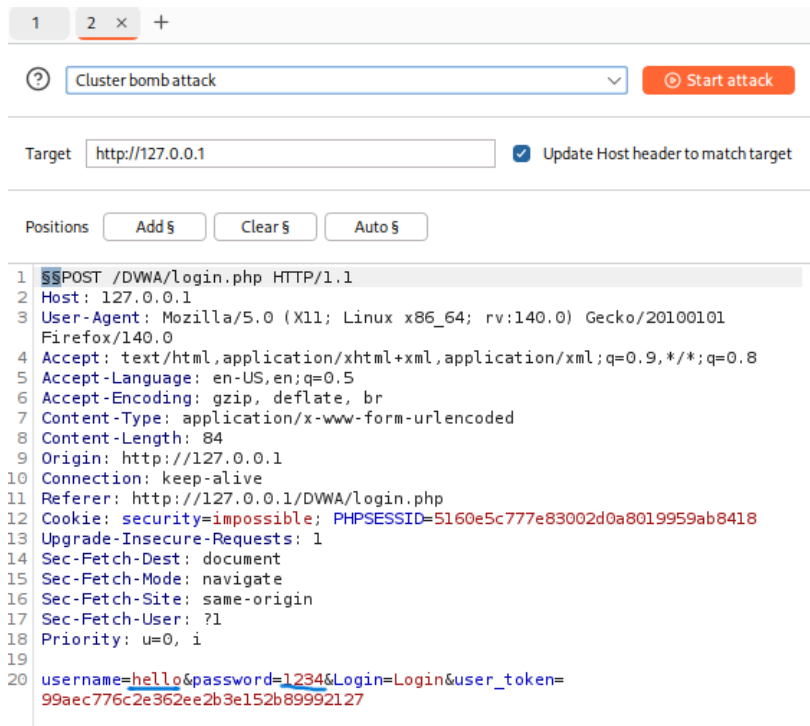


Рисунок 4.12: Выбор параметра для полезной нагрузки

На вкладке Payloads, поскольку мы выбрали два параметра полезной нагрузки (имя пользователя и пароль), я должен создать обе полезные нагрузки: сначала для имени пользователя. Я придумываю несколько имён, чтобы протестировать все варианты полезной нагрузки(рис. 4.13).

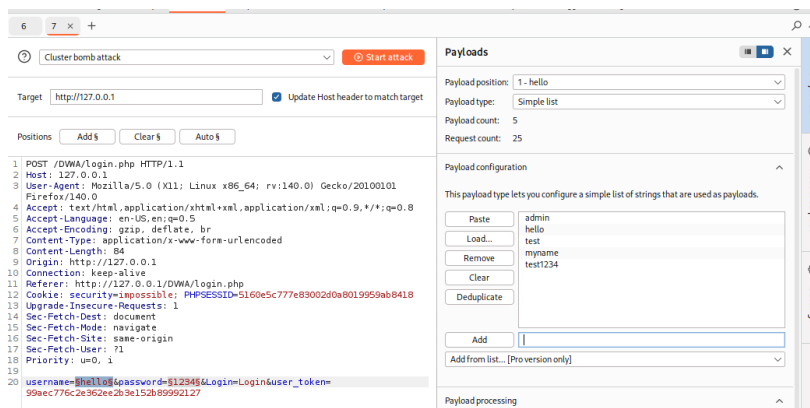


Рисунок 4.13: Создание полезной нагрузки для первого параметра

Затем я делаю то же самое для второго параметра, добавляя полезную

нагрузку(рис. 4.14).

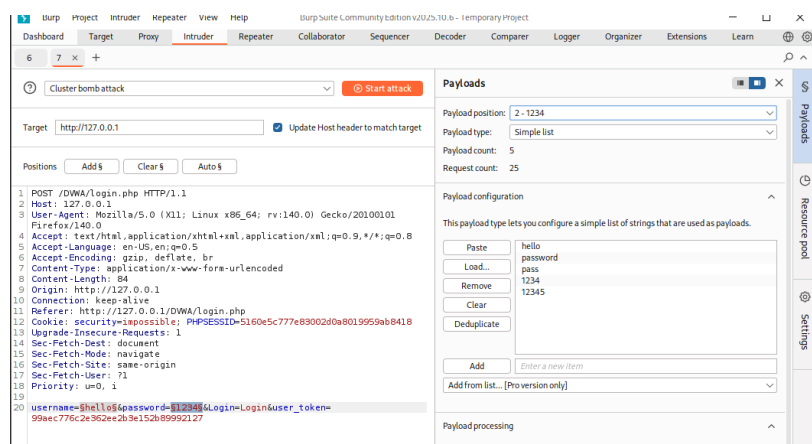


Рисунок 4.14: Создание полезной нагрузки для второго параметра

После завершения добавления полезных нагрузок я нажимаю Start attack и начинаю атаку. Burp Suite перебирает все полезные нагрузки, тестируя все возможные варианты для входа на сайт(рис. 4.15).

2. Intruder attack of http://127.0.0.1							
Results							
Capture filter: Capturing all items							
View filter: Showing all items							
Request	Payload 1	Payload 2	Status code	Response r...	Error	Timeout	Length
0			302	21			482
1	admin	hello	302	5			481
2	hello	hello	302	12			482
3	test	hello	302	4			481
4	myname	hello	302	4			481
5	test1234	hello	302	10			482
6	admin	password	302	5			481
7	hello	password	302	7			482

Рисунок 4.15: Начинаем атаку

После завершения процесса я выбираю результат. Во вкладке Response мы видим, куда произошло перенаправление после ввода пары логин-пароль. В данном случае пара test-hello перенаправила нас на login.php, то есть обратно на страницу входа — значит, эта пара не подходит(рис. 4.16).

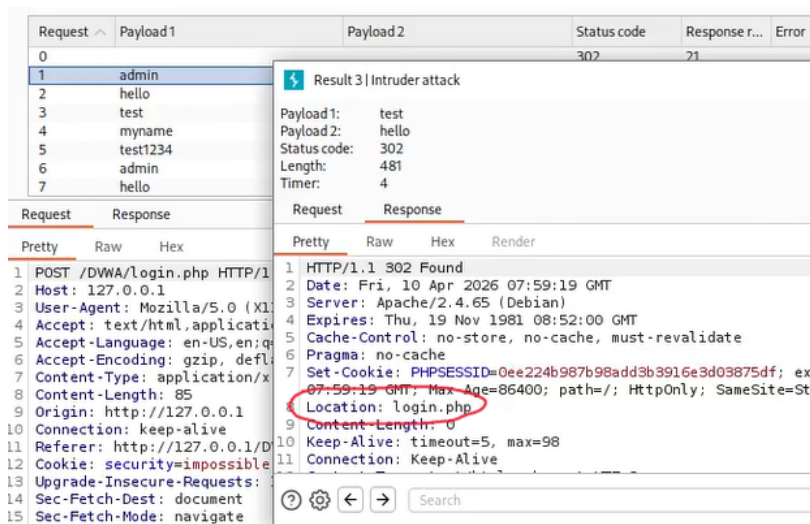


Рисунок 4.16: Результат проверки

Однако в случае пары admin-password произошло перенаправление на location index.php, который является домашней страницей DVWA — значит, эта пара подходит для входа(рис. 4.17).

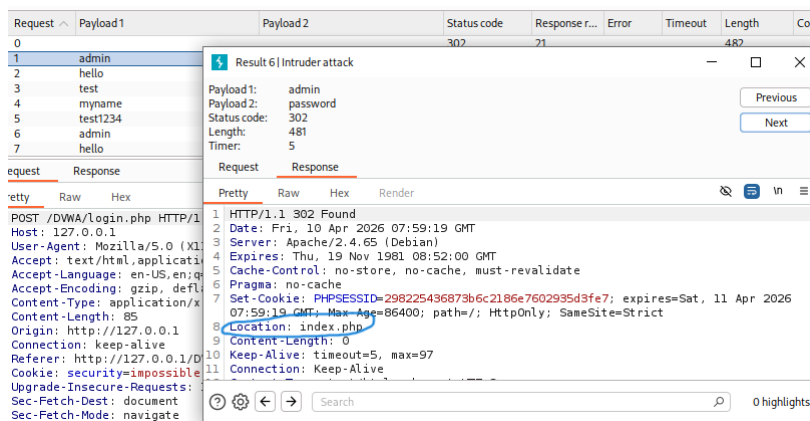


Рисунок 4.17: Результат проверки

Затем я выбираю эту пару и отправляю её в Repeater. На вкладке Repeater я нажимаю Send, чтобы отправить запрос. В результате мы перенаправляемся на index.php(рис. 4.18).

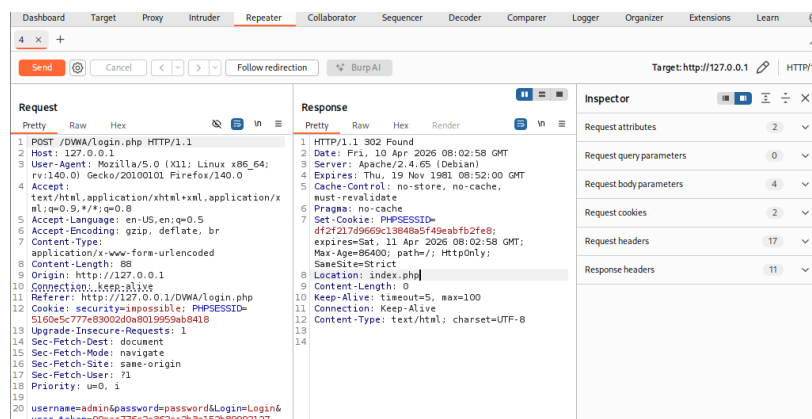


Рисунок 4.18: Отправка результата на вкладку «Repeater»

Я нажимаю Follow redirection и получаю HTML-код в окне Response(рис. 4.19).

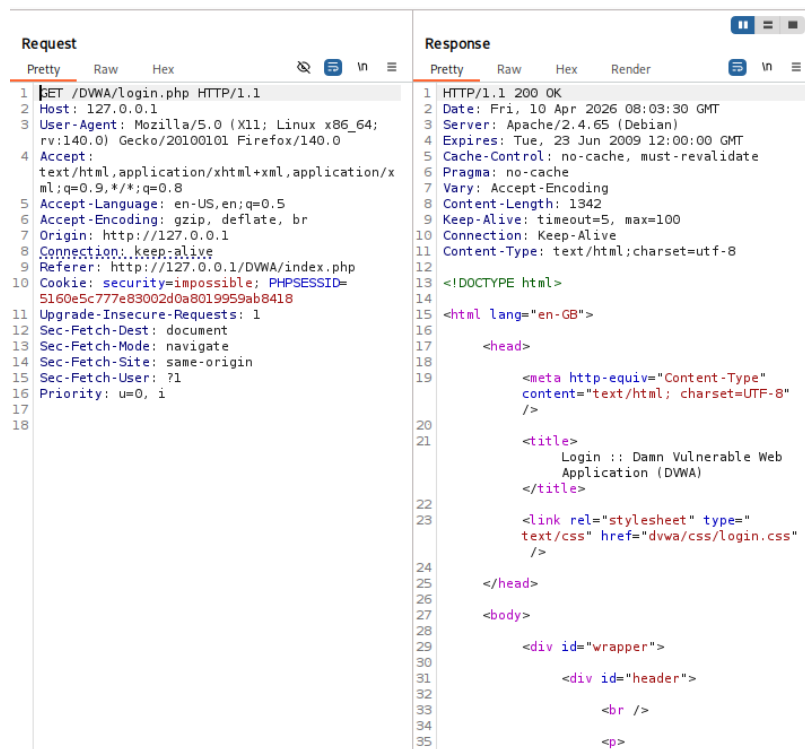


Рисунок 4.19: Отправка запроса на перенаправление

Чтобы увидеть структуру сайта, я перехожу в подокно Render и вижу результирующую страницу(рис. 4.20).

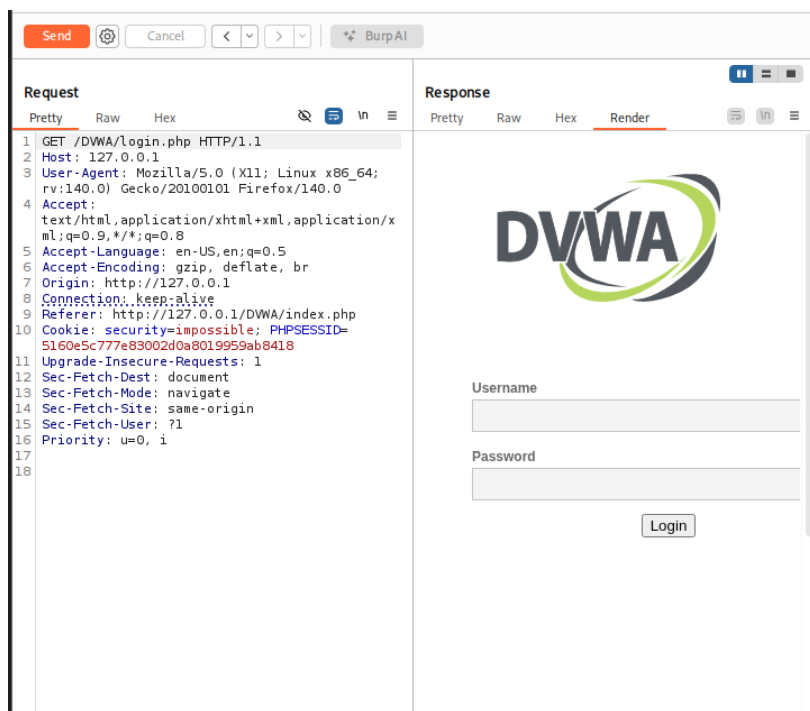


Рисунок 4.20: Визуализация сайта

5 Выводы

Я научился использовать Burp Suite